

ETSI EN 319 411-1/2 Certificate Policy and Certification Practice Statement

Goya Ledger Certificate Authority

Field	Value
Document title	Certificate Policy and Certification Practice Statement
CP OID	1.3.6.1.4.1.99999.2.1
CPS OID	1.3.6.1.4.1.99999.2.2
Version	1.0.0
Status	Active
Classification	Public
Applicable standards	ETSI EN 319 411-1, ETSI EN 319 411-2, RFC 3647
Jurisdiction	Republic of Chile
Governing law	Ley 19.799 (Firma Electronica), DS 181/2002, Decreto 24/2019
Effective date	2026-09-03

Table of Contents

1. [Scope](#)
2. [References](#)
3. [Definitions and Abbreviations](#)
4. [General Provisions](#)
5. [CA Key Life-Cycle Management](#)
6. [Certificate Life-Cycle Management](#)
7. [CA Management and Operation](#)
8. [Qualified Certificate Specific Requirements \(EN 319 411-2\)](#)

1. Scope

1.1 Overview

This document defines the Certificate Policy (CP) and Certification Practice Statement (CPS) of the Goya Ledger Certificate Authority (hereinafter “the CA”). It governs the issuance, management, revocation, and renewal of X.509v3 digital certificates within the Goya Ledger blockchain infrastructure.

The CA operates a two-tier hierarchy:

- **Root CA** (offline): Self-signed trust anchor with a 10-year validity period.
- **Intermediate CA** (operational): Subordinate CA with a 5-year validity period, constrained to issue end-entity certificates only (pathLenConstraint = 0).

1.2 Certificate Types

The CA issues certificates under three profiles:

Profile	OID (QcType)	Assurance Level	Intended Use
NaturalPerson (eSign)	0.4.0.1862.1.6.1	Low (FES) / High (FEA)	Electronic signatures by natural persons
LegalPerson (eSeal)	0.4.0.1862.1.6.2	High	Electronic seals for legal entities
WebAuthentication (QWAC)	0.4.0.1862.1.6.3	High	Website authentication

1.3 Applicability

This policy applies to:

- The Goya Ledger Root CA and Intermediate CA.
- The Registration Authority (RA) performing identity proofing.
- All subscribers and relying parties of certificates issued under this policy.
- All personnel involved in CA operations, key ceremonies, and audit functions.

1.4 Policy Identification

Attribute	Value
CP OID	1.3.6.1.4.1.99999.2.1
CPS OID	1.3.6.1.4.1.99999.2.2
OID root namespace	1.3.6.1.4.1.99999 (placeholder — IANA PEN registration pending at https://pen.iana.org/pen/ PenApplication.page; all OIDs in this

Attribute	Value
	document will be updated upon assignment)
CPS URI	https://goya.cl/pki/cp

2. References

2.1 Normative References

Reference	Title
ETSI EN 319 411-1	Policy and security requirements for Trust Service Providers issuing certificates – Part 1: General requirements
ETSI EN 319 411-2	Policy and security requirements for Trust Service Providers issuing certificates – Part 2: Requirements for qualified certificates
ETSI EN 319 412-1	Certificate profiles – Part 1: Overview and common data structures
ETSI EN 319 412-2	Certificate profiles – Part 2: Certificate profile for certificates issued to natural persons
ETSI EN 319 412-3	Certificate profiles – Part 3: Certificate profile for certificates issued to legal persons
ETSI EN 319 412-4	Certificate profiles – Part 4: Certificate profile for web site certificates (QWAC)
ETSI EN 319 412-5	Certificate profiles – Part 5: QCStatements
ETSI TS 102 042	Policy requirements for certification authorities issuing public key certificates
ETSI TS 101 903	XML Advanced Electronic Signatures (XAdES)
RFC 3647	Internet X.509 PKI Certificate Policy and Certification Practices Framework
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	Online Certificate Status Protocol (OCSP)
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)

2.2 Legislative References

Reference	Title
Ley 19.799	Ley sobre documentos electronicos, firma electronica y servicios de certificacion (Chile)
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Actualizacion del reglamento de firma electronica (Chile)
Regulation (EU) 910/2014	eIDAS – Electronic identification and trust services (informative)

2.3 Cryptographic Standards

Reference	Title
FIPS 140-3	Security Requirements for Cryptographic Modules (Level 1 minimum)
FIPS 186-5	Digital Signature Standard (Ed25519)
FIPS 204	Module-Lattice-Based Digital Signature Standard (ML-DSA-65)

3. Definitions and Abbreviations

3.1 Definitions

Term	Definition
Certificate Authority (CA)	Entity that issues, manages, and revokes digital certificates.
Registration Authority (RA)	Entity that verifies the identity of certificate applicants on behalf of the CA.
Subscriber	The entity named as the subject of a certificate.
Relying Party	An entity that relies on the validity of a certificate to verify a digital signature or authenticate an entity.
Key Ceremony	A formally witnessed procedure for generating, splitting, and activating CA key pairs.
Trust Anchor	The root CA certificate from which all trust chains derive.
Certificate Revocation List (CRL)	

Term	Definition
	A signed list of revoked certificate serial numbers, published by the CA per RFC 5280.
OCSP	Online Certificate Status Protocol, per RFC 6960.
RUT	Rol Unico Tributario, the Chilean national tax identifier.
FES	Firma Electronica Simple (Simple Electronic Signature).
FEA	Firma Electronica Avanzada (Advanced Electronic Signature).
HSM	Hardware Security Module.
QC	Qualified Certificate.
QWAC	Qualified Website Authentication Certificate.
QcType	ETSI EN 319 412-5 statement identifying the type of qualified certificate.
DID	Decentralized Identifier, format: <code>did:goya:{pubkey_hex[..16]}</code> .

3.2 Abbreviations

CA, CPS, CP, CRL, CSR, DER, DID, FEA, FES, HSM, OCSP, OID, PEM, PKI, RA, RUT, TSA, QC, QWAC.

4. General Provisions

4.1 Obligations

4.1.1 CA Obligations

The CA shall:

1. Issue certificates only after successful identity verification by the RA.
2. Publish Certificate Revocation Lists (CRLs) within one (1) hour of any revocation event.
3. Maintain audit logs for a minimum of seven (7) years.
4. Submit to annual inspection by the competent supervisory authority (Entidad Acreditadora).
5. Protect CA private keys in accordance with Section 5 of this policy.
6. Operate the Intermediate CA as the sole issuing CA; the Root CA shall remain offline except during scheduled key ceremonies.

7. Ensure all issued certificates contain the `certificatePolicies` extension (OID 2.5.29.32) referencing the CP OID and CPS URI.

4.1.2 RA Obligations

The RA shall:

1. Verify the identity of each applicant in accordance with Ley 19.799, Article 15.
2. Validate the applicant's RUT using the modulo 11 check-digit algorithm.
3. Retain identity proofing records for a minimum of seven (7) years.
4. Report suspicious identity claims to the CA within twenty-four (24) hours of detection.
5. Process identity proofing requests through the defined state machine: Pending, Verified, or Rejected. Only requests in the Pending state may be approved or rejected.

4.1.3 Subscriber Obligations

Subscribers shall:

1. Protect their private keys from unauthorized access, disclosure, or modification.
2. Report known or suspected key compromise to the CA within twenty-four (24) hours.
3. Provide accurate and complete identity information during the application process.
4. Use the certificate only for purposes authorized by the applicable certificate profile.
5. Cease use of the certificate upon expiration or revocation.

4.1.4 Relying Party Obligations

Relying parties shall:

1. Verify the certificate chain to the trusted Root CA before relying on any certificate.
2. Check the revocation status of the certificate via CRL or OCSP before reliance.
3. Verify that the certificate has not expired at the time of reliance.
4. Verify that the certificate is used consistently with the purposes indicated by its key usage and QcType extensions.

4.2 Liability

The CA accepts liability as defined by Ley 19.799 and its implementing regulations. The CA shall not be liable for damages arising from reliance on a certificate when the relying party failed to fulfil its obligations under Section 4.1.4.

4.3 Financial Responsibility

The CA shall maintain professional indemnity insurance with minimum coverage of EUR 500,000 per claim and EUR 1,000,000 aggregate per year, covering errors and omissions in certificate issuance, revocation delays, and key compromise. For

qualified certificates (AdES), the liability cap is EUR 100,000 per certificate as stated in the Subscriber Agreement (docs/policy/ACUERDO-SUSCRIPTOR.md). Insurance shall be obtained prior to commencing qualified trust services.

4.4 Interpretation and Enforcement

This policy is governed by the laws of the Republic of Chile. Disputes shall be resolved under Chilean jurisdiction. In the event of conflict between this policy and applicable legislation, the legislation shall prevail.

4.5 Publication and Repository

The CA shall publish the following at the CPS URI (<https://goya.cl/pki/cp>):

1. This Certificate Policy and Certification Practice Statement.
 2. The Root CA certificate.
 3. The Intermediate CA certificate.
 4. Current CRL (available at `/api/v1/crl` in DER format and `/api/v1/crl/pem` in PEM format).
 5. OCSP responder endpoints (`/api/v1/ocsp/query` and `/api/v1/ocsp/query/der`).
-

5. CA Key Life-Cycle Management

5.1 Key Generation

5.1.1 Root CA Key Generation

The Root CA key pair shall be generated during a formal key ceremony conducted in a physically secure, air-gapped environment. The ceremony is implemented in `src/pki_ceremony.rs` and shall satisfy the following requirements:

Requirement	Specification
Algorithm	ECDSA P-256 (NIST)
Random number generator	OS-backed CSPRNG (OsRng) with continuous health test
Minimum witnesses	2
Notary presence	Required
Ceremony roles	Administrator, Custodian, Witness, Auditor, Notary

The ceremony shall proceed through the following mandatory steps:

1. **Environment Check** – Verify the air-gapped status and physical security of the generation environment.
2. **Key Generation** – Generate the Root CA key pair using the approved CSPRNG.

3. **Witness Attestation** – All participants attest to the correct execution of the ceremony.
4. **Key Verification** – Verify the generated public key and self-signed certificate.
5. **Activation** – Activate the Root CA for operational use.

Optional steps (recorded but not mandatory for ceremony completion):

1. **Key Split** – Split the Root CA private key into M-of-N custodian shares using Shamir's Secret Sharing.
2. **Share Distribution** – Distribute shares to separate secure storage locations.

5.1.2 Intermediate CA Key Generation

The Intermediate CA key pair shall be generated on the operational CA system using the approved CSPRNG. The Intermediate CA certificate is signed by the Root CA during a scheduled ceremony.

Attribute	Value
Algorithm	ECDSA P-256 (NIST)
Validity	5 years from date of issuance
Basic Constraints	CA: TRUE, pathLenConstraint: 0

5.1.3 End-Entity Key Generation

End-entity key pairs are generated per-issuance by the CA infrastructure using the approved CSPRNG. Each certificate issuance and each renewal generates a fresh key pair.

5.2 Key Protection

5.2.1 Private Key Storage

Key Type	Protection Mechanism
Root CA	Shamir's Secret Sharing (default: 2-of-3 threshold). Shares stored in separate secure locations. Key reconstructed only during scheduled ceremonies in air-gapped environments.
Intermediate CA	In-memory with ZeroizeOnDrop. Never persisted to disk in plaintext. HSM protection via PKCS#11 when the hsm feature gate is enabled.
End-entity	Delivered to the subscriber. The CA does not retain copies of subscriber private keys.

5.2.2 Key Ceremony Integrity

Each key ceremony produces a CeremonyRecord whose integrity is protected by a SHA-256 hash computed over: record identifier, ceremony type, key fingerprint, key algorithm, start timestamp, completion timestamp, participant count, and step count. The `verify_record()` function recomputes the hash to detect tampering.

5.2.3 HSM Requirements

When the hsm feature gate is enabled, CA private keys shall be protected by a PKCS#11-compliant Hardware Security Module meeting FIPS 140-3 Level 1 or higher. HSM-based key backup shall be used for the Intermediate CA.

5.3 Key Usage Periods

Key Type	Operational Period	Certificate Validity
Root CA	10 years	2026-09-03 to 2034-01-01
Intermediate CA	5 years	5 years from issuance
FES Subscriber	365 days	365 days
FEA Subscriber	365 days	365 days
TSA Signing	730 days	730 days

5.4 Key Archival and Destruction

Root CA key shares shall be archived in tamper-evident containers at geographically separated locations. Destruction of CA keys shall require the authorization of the CA Administrator and shall be witnessed and documented.

End-entity private key material held in memory shall be zeroized upon scope exit using the `ZeroizeOnDrop` trait. The CA does not archive subscriber private keys.

5.5 Cryptographic Algorithm Suite

The CA supports the following algorithms:

Algorithm	Standard	Use
ECDSA P-256	NIST FIPS 186-5	CA certificates, end-entity certificates (default)
Ed25519	FIPS 186-5	FES subscriber signatures
ML-DSA-65	FIPS 204	FEA subscriber signatures (post-quantum)

Signature values are stored as `Vec<u8>` to accommodate variable-length signatures (Ed25519: 64 bytes; ML-DSA-65: 3309 bytes). Signatures are hex-serialized for transport using the `vec_hex` serialization module.

6. Certificate Life-Cycle Management

6.1 Application and Registration

6.1.1 Identity Proofing

All certificate applicants shall undergo identity proofing through the Registration Authority. The RA implements the following workflow (defined in `src/identity/ra.rs`):

1. **Submission** – The applicant submits an identity proofing request containing:
 - Decentralized Identifier (DID), format: `did:goya:{pubkey_hex[..16]}`
 - RUT (Chilean national tax identifier)
 - Legal name
 - Proofing method
2. **RUT Validation** – The RA validates the RUT using the modulo 11 check-digit algorithm. Accepted formats: 12345678–5, 12.345.678–5, 123456785. The check digit K is supported.
3. **Identity Verification** – The RA officer verifies the applicant’s identity using one of the approved proofing methods:
 - **In Person** – Physical presence with government-issued identification.
 - **Video Conference** – Real-time video session with document verification.
 - **Remote Automated** – Automated document and biometric verification.
4. **Decision** – The RA officer approves or rejects the request. The state machine enforces that only requests in the `Pending` state may be transitioned. Rejection requires a documented reason.

6.1.2 Uniqueness

The RA enforces a single active proofing request per DID. Duplicate submissions for the same DID are rejected.

6.1.3 Re-Verification

Identity proofing shall be re-verified at intervals not exceeding thirty-six (36) months.

6.2 Certificate Issuance

6.2.1 Issuance Process

Upon successful identity verification, the CA issues a certificate through the following process:

1. The RA approves the identity proofing request and transitions its status to **Verified**.
2. The CA generates a fresh key pair for the subscriber.
3. The CA constructs the X.509v3 certificate with the appropriate profile, extensions, and validity period.
4. The Intermediate CA signs the certificate.
5. The certificate, private key (PEM), and full chain (PEM) are delivered to the subscriber.

The `approve_and_issue_cert()` function in `src/identity/ra.rs` performs steps 1 through 5 atomically.

6.2.2 Certificate Content

All issued certificates shall contain:

Extension / Field	OID	Content
Version	—	v3
Serial Number	—	Unique, cryptographically random
Signature Algorithm	—	ML-DSA-65 (FIPS 204) for FEA certificates; ECDSA P-256 (FIPS 186-5) for OID4VCI interoperability tokens; Ed25519 (RFC 8032) for FES certificates
Issuer	—	Intermediate CA distinguished name
Validity	—	Per profile (see Section 5.3)
Subject	—	Subscriber identity (node ID / DID)
Basic Constraints	2.5.29.19	CA: FALSE
Certificate Policies	2.5.29.32	CP OID 1.3.6.1.4.1.99999.2.1, CPS URI https://goya.cl/pki/cp
Key Usage	2.5.29.15	Per profile (digitalSignature, nonRepudiation)
Extended Key Usage	2.5.29.37	

Extension / Field	OID	Content
		Per profile (id-kp-serverAuth for QWAC, id-kp-timeStamping for TSA)
Subject Alternative Name	2.5.29.17	Per profile (FQDN for QWAC, email for natural persons)
Authority Information Access	1.3.6.1.5.5.7.1.1	OCSP: https://goya.cl/pki/ocsp , CA Issuers: https://goya.cl/pki/ca.crt
CRL Distribution Points	2.5.29.31	https://goya.cl/pki/crl.der
QCStatements	1.3.6.1.5.5.7.1.3	QcCompliance (0.4.0.1862.1.1) + QcType per profile

6.2.3 Certificate Profiles

FES Subscriber Certificate (Simple Electronic Signature)

Attribute	Value
Profile type	NaturalPerson
Assurance level	Low
Key usage	digitalSignature
QcType	id-etsi-qct-esign (0.4.0.1862.1.6.1)
Validity	365 days

FEA Subscriber Certificate (Advanced Electronic Signature)

Attribute	Value
Profile type	NaturalPerson
Assurance level	High
Key usage	digitalSignature, nonRepudiation
QcType	id-etsi-qct-esign (0.4.0.1862.1.6.1)
Validity	365 days

Legal Person eSeal Certificate

Attribute	Value
Profile type	LegalPerson
Assurance level	High
Key usage	digitalSignature, nonRepudiation
QcType	id-etsi-qct-eseal (0.4.0.1862.1.6.2)

Attribute	Value
Validity	365 days

Website Authentication Certificate (QWAC) — per ETSI EN 319 412-4

Attribute	Value
Profile type	WebAuthentication
Assurance level	High
Key usage	digitalSignature, keyEncipherment
Extended Key Usage	id-kp-serverAuth (1.3.6.1.5.5.7.3.1)
Subject	O=Goya Ledger SpA, organizationIdentifier=NTRCL- {RUT}, C=CL
Subject Alternative Name	FQDN(s) of the web service (e.g., goya-node.fly.dev)
QcType	id-etsi-qct-web (0.4.0.1862.1.6.3)
Domain validation	Per CA/Browser Forum Baseline Requirements section 3.2.2
Validity	365 days

TSA Signing Certificate

Attribute	Value
Profile type	NaturalPerson
Assurance level	High
Key usage	digitalSignature
Extended Key Usage	id-kp-timeStamping (1.3.6.1.5.5.7.3.8)
Validity	730 days

6.3 Certificate Acceptance

The subscriber shall be deemed to have accepted the certificate upon first use or upon the expiration of a reasonable review period (not exceeding seven calendar days), whichever occurs first. If the subscriber identifies any inaccuracy in the certificate content, the subscriber shall notify the CA immediately and refrain from using the certificate until the issue is resolved.

6.4 Certificate Usage

Certificates issued under this policy shall be used only for the purposes consistent with:

1. The key usage extension specified in the certificate.
2. The QcType statement, where present.

3. The certificate profile under which the certificate was issued.

Use of a certificate for purposes inconsistent with these constraints shall constitute a breach of this policy.

6.5 Certificate Renewal

6.5.1 Renewal Process

Certificate renewal generates a new key pair and a new certificate for an existing, verified subscriber identity. The process is implemented in `src/pki.rs` via `renew_node_cert()`:

1. The CA verifies that the subscriber's identity proofing remains valid (within the 36-month re-verification window).
2. The old certificate shall be revoked prior to or concurrently with renewal.
3. A fresh key pair is generated.
4. A new certificate is issued under the same subscriber identity (node ID) with a new serial number and validity period.

6.5.2 Renewal Eligibility

A certificate may be renewed if:

- The subscriber's identity proofing has not expired.
- The existing certificate has not been revoked for cause (key compromise or affiliation change).
- The subscriber remains in compliance with this policy.

6.6 Certificate Suspension and Reinstatement

6.6.1 Suspension

A certificate may be temporarily suspended by the CA when:

- The subscriber requests suspension.
- A potential key compromise is under investigation.
- The RA identifies a discrepancy in the subscriber's identity information.

Suspended certificates are recorded with the CRL reason code `certificateHold` and included in the next CRL publication. Suspension is implemented via `suspend_and_publish_crl()` in `src/pki_lifecycle.rs`.

6.6.2 Reinstatement

A suspended certificate may be reinstated if the investigation concludes that no compromise or policy violation occurred. Reinstatement removes the `certificateHold` entry from subsequent CRL publications. Reinstatement is implemented via `reinstate_and_publish_crl()`.

6.7 Certificate Revocation

6.7.1 Circumstances for Revocation

The CA shall revoke a certificate when:

1. The subscriber's private key is known or suspected to be compromised.
2. The subscriber has violated the obligations set forth in Section 4.1.3.
3. The information in the certificate is or becomes inaccurate.
4. The subscriber requests revocation.
5. The CA ceases operations.
6. The certificate was issued in violation of this policy.

6.7.2 Revocation Process

1. The CA receives and validates the revocation request.
2. The certificate serial number is recorded as revoked in the MSP (Membership Service Provider) registry.
3. A new CRL is generated and published. The CRL number is atomically incremented.
4. A CertificateRevoked lifecycle event is recorded for audit purposes.

Revocation is implemented via `revoke_and_publish_crl()` in `src/pki_lifecycle.rs`.

6.7.3 CRL Publication

Attribute	Value
Format	DER-encoded, per RFC 5280
Endpoints	<code>/api/v1/crl</code> (DER), <code>/api/v1/crl/pem</code> (PEM)
Publication deadline	Within one (1) hour of any revocation event
CRL numbering	Monotonically increasing AtomicU64, starting at 1
Content	All revoked and suspended certificate serial numbers

6.7.4 OCSP

The CA provides an OCSP responder conforming to RFC 6960 at the following endpoints:

Endpoint	Format
<code>/api/v1/ocsp/query</code>	HTTP POST, <code>application/ocsp-request</code>
<code>/api/v1/ocsp/query/der</code>	HTTP POST, DER-encoded request

6.8 Expiry Monitoring

The lifecycle manager (`src/pki_lifecycle.rs`) continuously monitors certificate validity periods and generates `CertificateExpiring` events for certificates approaching expiration within the configured warning window (default: 30 days). These events may trigger renewal notifications to subscribers.

7. CA Management and Operation

7.1 Physical Security

7.1.1 Root CA Environment

The Root CA shall operate exclusively in an air-gapped environment. Physical access shall be restricted to authorized personnel during scheduled key ceremonies. The environment check is the first mandatory step of every key ceremony (Section 5.1.1).

7.1.2 Intermediate CA Environment

The Intermediate CA shall operate in a physically secured facility with access controls, environmental monitoring, and intrusion detection.

7.2 Procedural Controls

7.2.1 Trusted Roles

The CA defines the following trusted roles, implemented in `src/pki_ceremony.rs`:

Role	Responsibilities
Administrator	Authorizes key ceremonies and CA operations.
Custodian	Holds one share of the Root CA private key (M-of-N scheme). Minimum: 3 custodians for a 2-of-3 threshold.
Witness	Attests to the correct execution of key ceremonies. Minimum: 2 witnesses per ceremony.
Auditor	Reviews ceremony records and audit logs.
Notary	Provides notarial attestation of the key ceremony. Required by default.

7.2.2 Separation of Duties

No single individual shall hold more than one trusted role during a key ceremony. The ceremony validation logic enforces that the required number of participants per role is met before the ceremony can be finalized.

7.3 Personnel Security

All personnel performing trusted roles shall be subject to background verification and shall acknowledge in writing their obligations under this policy.

7.4 Audit Logging

7.4.1 Events Logged

The CA shall record the following events:

- Certificate issuance, renewal, suspension, reinstatement, and revocation.
- CRL publications (with CRL number and timestamp).
- Key ceremony execution (all steps, participants, and record hashes).
- RA identity proofing decisions (submission, approval, rejection with reason).
- Administrative actions on the CA system.

7.4.2 Log Integrity

Ceremony records are integrity-protected via SHA-256 hashes (see Section 5.2.2). Audit logs shall be stored in append-only storage. When `STORAGE_BACKEND=rocksdb` and `RUST_BC_ENV=production`, audit logs are persisted to RocksDB.

7.4.3 Retention Period

All audit logs and identity proofing records shall be retained for a minimum of seven (7) years.

7.5 Records Archival

The CA shall archive the following records for a minimum of seven (7) years:

1. All issued certificates (including revoked and expired certificates).
2. All CRLs published during the retention period.
3. Identity proofing records and supporting documentation.
4. Key ceremony records.
5. Audit logs.

7.6 Certificate Chain Validation

The CA provides chain validation services implemented in `src/pki_chain.rs`. Validation performs the following checks in order:

1. Parse the PEM certificate chain into DER-encoded certificates.
2. Extract certificate metadata (subject, issuer, validity period, isCA flag).
3. Verify the validity period of every certificate in the chain against the current time.
4. Verify issuer-subject linkage: for each certificate at index `i`, `cert[i].issuer` must equal `cert[i+1].subject`.
5. Verify that the root certificate is self-signed or chains to a certificate in the trust store.
6. Verify that all non-leaf certificates have the CA basic constraint set to TRUE.

The chain supports two-tier (Root + Intermediate + Leaf = 3 levels) and single-tier (self-signed root) topologies.

7.7 Compromise and Disaster Recovery

In the event of a suspected or confirmed compromise of the Intermediate CA:

1. The Intermediate CA shall be immediately taken offline.
2. All certificates issued by the compromised Intermediate CA shall be revoked.
3. A new Intermediate CA key pair shall be generated and certified by the Root CA via a key ceremony.
4. A new CRL shall be published reflecting all revocations.

In the event of Root CA compromise, the CA shall:

1. Notify all relying parties and the supervisory authority.
2. Cease issuance of all certificates.
3. Initiate a full re-establishment of the CA hierarchy.

7.8 CA Termination

Upon termination of CA operations:

1. All outstanding certificates shall be revoked.
2. A final CRL shall be published.
3. All CA private keys shall be destroyed in a witnessed ceremony.
4. Archive records shall be transferred to a successor entity or the supervisory authority.
5. Subscribers and relying parties shall be notified at least ninety (90) days prior to termination.

7.9 Data Protection (EN 319 411-1 clause 6.4)

The CA processes personal data of subscribers in accordance with GDPR (EU 2016/679) and Ley 19.628 (Chile).

Data category	Purpose	Retention	Legal basis
Subscriber name, email	Certificate issuance	7 years post-expiry	Contract (Art. 6(1)(b))
National ID / RUT	Identity verification (RA)	7 years	Legal obligation (Ley 19.799)
Biometric commitments (SHA-256)	FEA identity binding	Certificate validity	Explicit consent (Art. 9(2)(a))
Public keys, certificates	PKI operation	7 years post-expiry	Legitimate interest

Raw biometric data is never transmitted to or stored by the CA. Only SHA-256 commitments are processed. A Data Protection Impact Assessment is documented in docs/policy/POLITICA-PRIVACIDAD-EIPD.md.

Subscriber rights (access, rectification, erasure subject to retention obligations, portability) are exercised through the RA per PO04.

8. Qualified Certificate Specific Requirements (EN 319 411-2)

This section specifies additional requirements for qualified certificates issued under ETSI EN 319 411-2, supplementing the general requirements of Sections 1 through 7.

8.1 Scope of Qualified Certificates

The CA issues qualified certificates of the following types, as identified by the QcType statement (OID 0.4.0.1862.1.6) in the QCStatements extension (OID 1.3.6.1.5.5.7.1.3):

QC Type	QcType OID	ETSI EN 319 412-5 Identifier	Description
QC for eSignature	0.4.0.1862.1.6.1	id-etsi-qct-esign	Qualified certificate for electronic signatures (natural persons)
QC for eSeal	0.4.0.1862.1.6.2	id-etsi-qct-eseal	Qualified certificate for electronic seals (legal persons)
QC for Web Auth	0.4.0.1862.1.6.3	id-etsi-qct-web	Qualified certificate for

QC Type	QcType OID	ETSI EN 319 412-5 Identifier	Description
			website authentication

8.2 QCStatements Extension

All qualified certificates shall include the QCStatements extension (OID 1.3.6.1.5.5.7.1.3) containing:

1. **QcCompliance** (OID 0.4.0.1862.1.1): Asserts that the certificate is issued as a qualified certificate in accordance with applicable legislation.
2. **QcType** (OID 0.4.0.1862.1.6): Identifies the specific type of qualified certificate, with the sub-OID corresponding to the certificate profile (see Section 8.1).

The QCStatements extension is constructed per ETSI EN 319 412-5 and is embedded in every qualified certificate at issuance time.

8.3 Identity Proofing for Qualified Certificates

8.3.1 Natural Persons (eSign)

For qualified certificates issued to natural persons, the RA shall verify:

1. The legal name of the applicant, confirmed against a government-issued identification document.
2. The applicant's RUT, validated using the modulo 11 algorithm.
3. The applicant's control over the DID presented in the application.

For FEA (Advanced Electronic Signature) certificates, the proofing method shall be In Person or Video Conference. Remote Automated proofing is permitted only for FES (Simple Electronic Signature) certificates at the Low assurance level.

8.3.2 Legal Persons (eSeal)

For qualified certificates issued to legal persons, the RA shall additionally verify:

1. The legal existence and identity of the organization.
2. The authority of the natural person acting on behalf of the legal entity.
3. The organization's RUT.

8.3.3 Website Authentication (QWAC)

For qualified website authentication certificates, the RA shall verify:

1. The applicant's right to use the domain name(s) included in the certificate.
2. The identity of the legal entity operating the website.

8.4 Qualified Signature/Seal Creation Device (QSCD) Requirements

For qualified certificates supporting advanced electronic signatures (FEA) or electronic seals, the private key shall be generated and stored in a Qualified Signature/Seal Creation Device (QSCD) meeting the requirements of:

- ETSI EN 419 211 (Protection profiles for secure signature creation devices), or
- An equivalent standard recognized by the supervisory authority.

When the hsm feature gate is enabled, the PKCS#11 interface provides the integration point for QSCD-compliant devices.

8.5 Certificate Profile Compliance

Qualified certificates shall conform to the applicable certificate profile standards:

Certificate Type	Applicable Profile Standard
Natural person (eSign)	ETSI EN 319 412-2
Legal person (eSeal)	ETSI EN 319 412-3
Website authentication (QWAC)	ETSI EN 319 412-4

8.6 Revocation Service Availability

For qualified certificates, the CA shall ensure:

1. CRL and OCSP services are available 24 hours per day, 7 days per week.
2. CRL publication occurs within one (1) hour of any revocation event (as specified in Section 6.7.3).
3. OCSP responses are signed and include the current revocation status at the time of the query.
4. Service availability targets meet or exceed 99.5% annual uptime.

8.7 Supervision and Conformity Assessment

The CA shall:

1. Submit to initial and periodic conformity assessment by a qualified conformity assessment body.
2. Maintain its status on the national Trusted List maintained by the supervisory authority.
3. Notify the supervisory authority of any security breach or integrity compromise within twenty-four (24) hours.
4. Comply with the requirements of Ley 19.799 and the Entidad Acreditadora's inspection guidelines.

8.8 TSA Policy

The CA issues TSA signing certificates under TSA Policy OID 1.3.6.1.4.1.99999.1.1. Time-stamp tokens shall conform to RFC 3161 and ETSI TS 101 903 (XAdES).

8.9 Signature Policy

Electronic signatures produced using certificates issued under this CP/CPS may reference the Goya Ledger Signature Policy, identified by OID 1.3.6.1.4.1.99999.3.1, for XAdES signature validation.

Appendix A: OID Summary

OID	Description
1.3.6.1.4.1.99999	Goya Ledger OID root (IANA PEN)
1.3.6.1.4.1.99999.1.1	TSA Policy
1.3.6.1.4.1.99999.2.1	Certificate Policy (CP)
1.3.6.1.4.1.99999.2.2	Certification Practice Statement (CPS)
1.3.6.1.4.1.99999.3.1	XAdES Signature Policy
2.5.29.32	certificatePolicies extension
1.3.6.1.5.5.7.1.3	QCStatements extension
0.4.0.1862.1.1	id-etsi-qcs-QcCompliance
0.4.0.1862.1.6	id-etsi-qcs-QcType
0.4.0.1862.1.6.1	id-etsi-qct-esign
0.4.0.1862.1.6.2	id-etsi-qct-eseal
0.4.0.1862.1.6.3	id-etsi-qct-web

Appendix B: Source Code Cross-Reference

Component	Source File	Purpose
CA hierarchy and certificate issuance	src/pki.rs	Root CA, Intermediate CA, end-entity certificate generation
Policy definitions and OIDs	src/pki_policy.rs	CP/CPS metadata, certificate profiles, compliance references
Certificate lifecycle management	src/pki_lifecycle.rs	Revocation, suspension, reinstatement, CRL publication, expiry monitoring
Certificate chain validation	src/pki_chain.rs	

Component	Source File	Purpose
		X.509 chain validation (issuer linkage, validity, CA constraints)
Key ceremony procedures	src/pki_ceremony.rs	Air-gapped key generation, Shamir splitting, witness attestation
Registration Authority	src/identity/ra.rs	Identity proofing workflow, RUT validation, certificate issuance upon approval

Appendix C: Revision History

Version	Date	Author	Description
1.0.0	2026-09-03	Goya Ledger CA	Initial publication